

CHALLENGE #12: SQLiLite Write-up.

SQLiLite

Medium

Web Exploitation

picoCTF 2022

sql

AUTHOR: MUBARAK MIKAIL

Description

Can you login to this website?
Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.
Its current status is:
NOT_RUNNING

Launch Instance

Hints

1
admin is the user you want to login as.

33,256 users solved

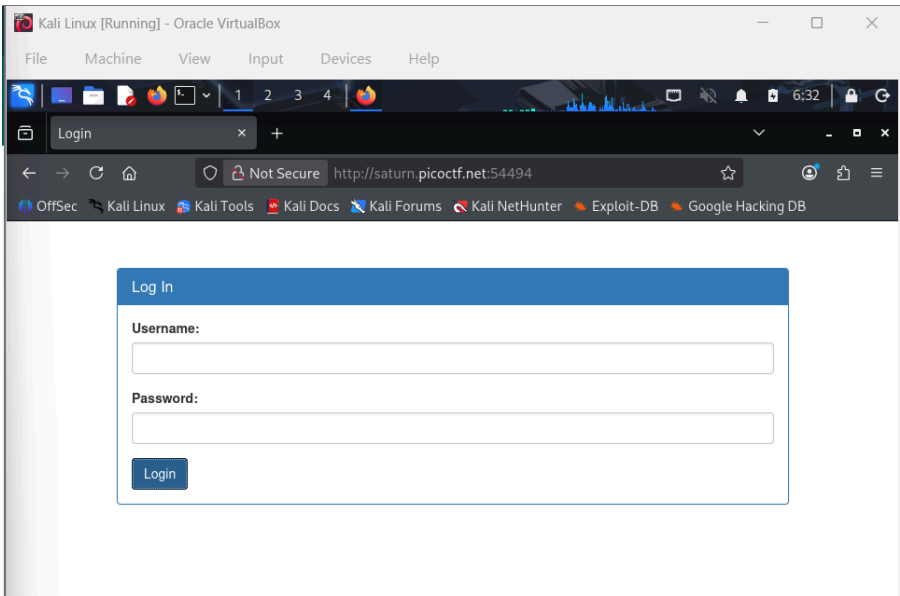
93% Liked

picoCTF{FLAG}

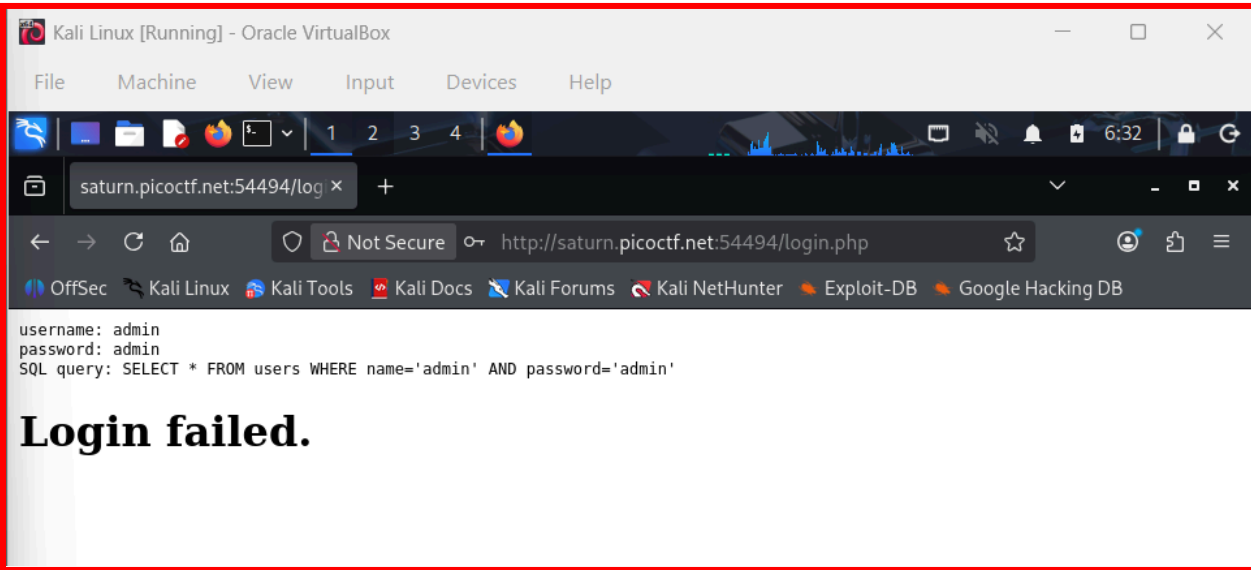
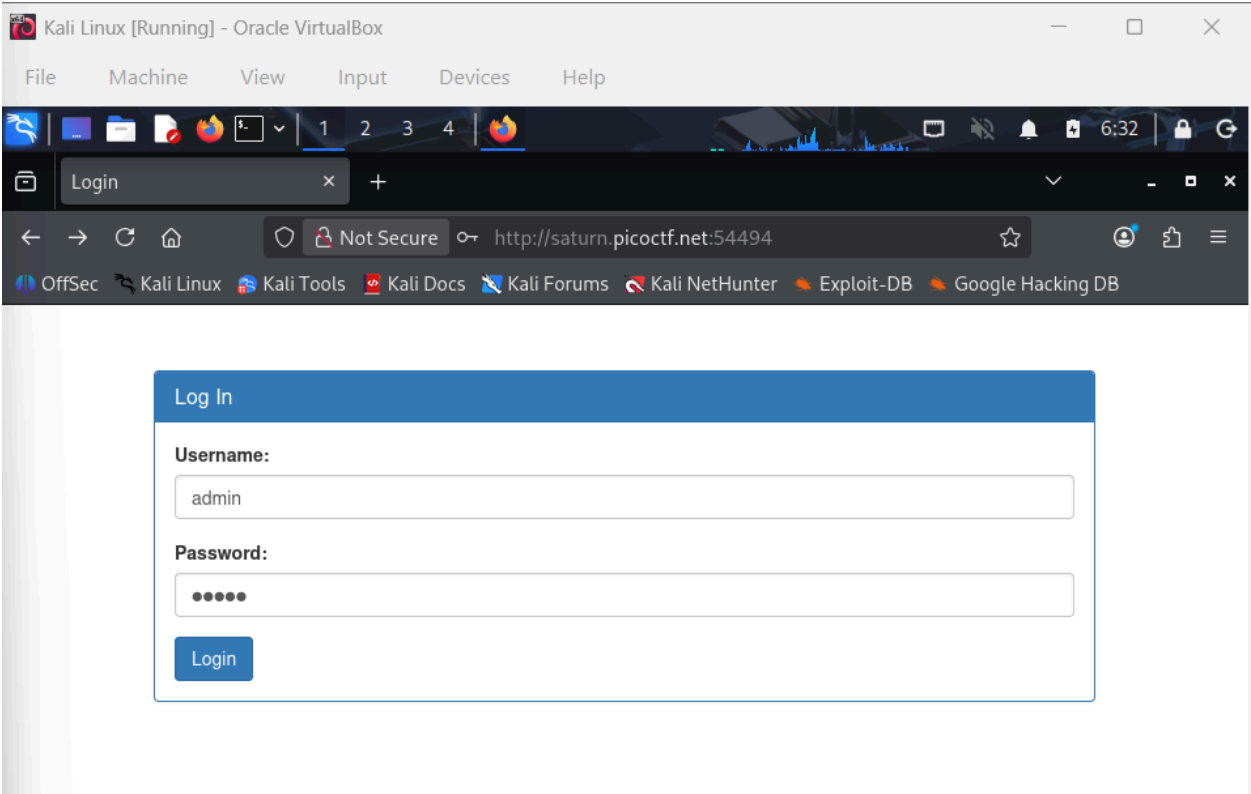
Submit Flag

Solving Process:

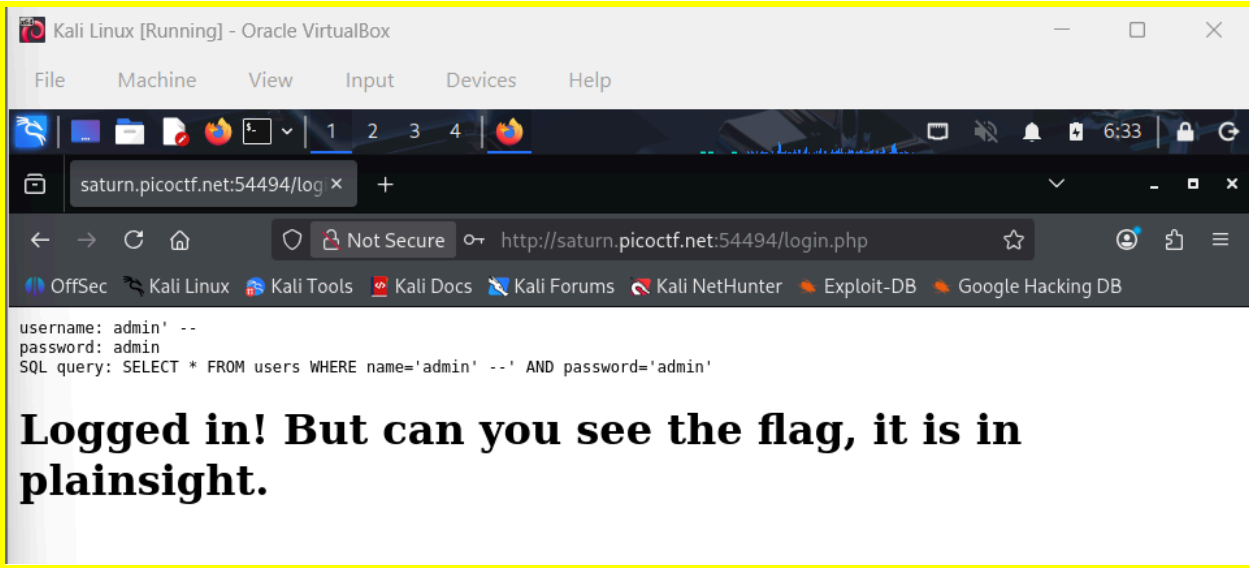
The page displayed a **login form**, and the objective of the challenge was to **bypass the login system to obtain the flag**. Since the challenge was titled SQLiLite, it suggested that the vulnerability likely involved **SQL injection**.



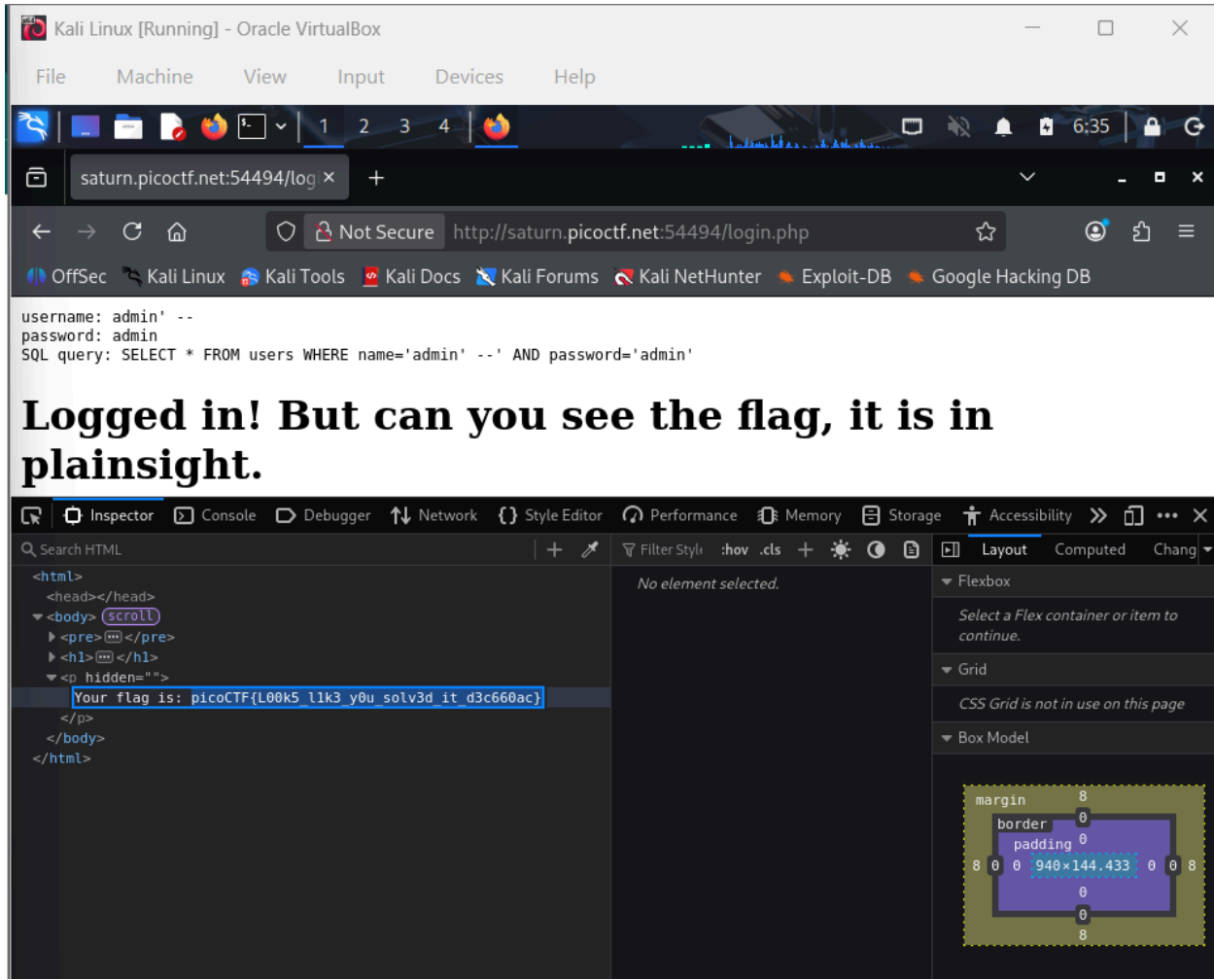
To begin testing the login system, the username **admin** and password **admin** were entered and the Login button was clicked. The login attempt failed, but the page displayed the SQL query being executed by the application. The query showed that the system was selecting records from the users table and checking whether the provided username and password matched a record in the database.



Since the application revealed how the query was constructed, it indicated that the login system might be vulnerable to SQL injection. To test this, the username field was modified by entering **admin'--** and then clicking the Login button. The **single quote (')** closed the original username string in the SQL query, while the **two dashes (--)** indicated a comment in SQL. This caused the rest of the query, including the password condition, to be ignored by the database. As a result, the modified query effectively checked only whether the username was **admin**, which allowed the login process to succeed without verifying the password. After logging in successfully, the page displayed a message stating that the flag was in plain sight, suggesting that it might be hidden somewhere within the page.



To investigate further, the page source was viewed. Upon examining the HTML code, a hidden input field was discovered that contained the flag within its value attribute.



SQLiLite



Medium

Web Exploitation

picoCTF 2022

sql

AUTHOR: MUBARAK MIKAIL

Description

Can you login to this website?

Try to login [here](#).

This challenge launches an instance on demand.

Its current status is: **RUNNING**

Instance Time Remaining: **14:53**

Restart Instance

Hints ?

1

admin is the user you want to login as.

33,256 users solved



93% Liked



 `picoCTF{L00k5_l1k3_y0u_solv3d_it_d3c660ac}`

Submit Flag

Hurray! You solved this challenge.

Reflection:

This challenge demonstrated how improperly handled SQL queries can lead to SQL injection vulnerabilities, allowing attackers to bypass authentication. By manipulating the input to alter the SQL query logic, it was possible to log in without knowing the correct password. The activity emphasized the importance of using parameterized queries, proper input validation, and secure database practices to prevent SQL injection attacks.